

## Guía metodológica de la Encuesta STRIDE

### 1. Propósito y alcance

La presente guía acompaña a la “Encuesta STRIDE de Madurez y Métricas de Ciberseguridad” y está diseñada para organizaciones españolas sometidas (o próximamente sometidas) a las exigencias de NIS2, ENS y marcos sectoriales afines. [web:31][web:34]

El objetivo no es únicamente medir el grado de cumplimiento, sino entender cómo se gestionan, en la práctica, las seis categorías STRIDE: suplantación, manipulación, repudiación, divulgación, denegación de servicio y escalada de privilegios. La encuesta se centra en indicadores cuantificables o categorizables, para permitir el cálculo de índices de madurez y análisis de brechas.

### 2. Población objetivo y roles recomendados

La encuesta está pensada para ser respondida colectivamente por:

- CISO o responsable de seguridad de la información.
- Responsables de arquitectura, desarrollo y operaciones.
- Responsables de negocio que gestionan servicios esenciales o críticos.
- En su caso, responsables de cumplimiento, jurídico, riesgo operacional y continuidad de negocio.

Se recomienda evitar tanto el monopolio técnico (todo en manos del equipo de seguridad) como el monopolio burocrático (todo en manos de cumplimiento sin visión técnica) y favorecer sesiones conjuntas de 60–90 minutos.

### 3. Estructura de la encuesta

La encuesta se organiza en bloques:

1. Datos generales de la organización.
2. Gobierno y proceso de threat modeling.
3. Spoofing (identidad).
4. Tampering (integridad).
5. Repudiation (trazabilidad).
6. Information Disclosure (confidencialidad).
7. Denial of Service (disponibilidad y resiliencia).
8. Elevation of Privilege (privilegios y accesos).
9. Métricas, ROI y mejora continua.
10. Comentarios finales.

Cada pregunta está formulada para:

- Permitir una respuesta elegible categórica (tipo Likert, ordinal o binaria).
- Reflejar prácticas observables y auditables (no solo intenciones).
- Facilitar el mapeo a requisitos normativos (NIS2, ENS, etc.) y a las seis letras de STRIDE.

## 4. Metodología de aplicación

### 4.1. Modalidad de respuesta

La encuesta puede aplicarse de tres formas:

11. Autodiagnóstico individual: un responsable la completa.
12. Taller dirigido: un facilitador (interno o externo) modera una sesión de trabajo.
13. Proceso híbrido: cada área responde su parte y se consolidan respuestas.

En todos los casos, debe quedar claro:

- Fecha de realización.
- Ámbito (toda la organización, una unidad concreta, un servicio esencial).
- Participantes y sus roles.

### 4.2. Escala de madurez implícita

Aunque las respuestas son categóricas, cada opción se corresponde con un nivel implícito de madurez, alineado con prácticas habituales en marcos de capacidad y con la literatura reciente sobre threat modeling y métricas. [web:8][web:32][web:38]

A título general:

- Opciones que implican procesos formalizados, medidos y revisados representan niveles altos de madurez.
- Opciones que reflejan prácticas informales o reactivas representan niveles intermedios.
- Opciones que denotan ausencia de proceso o desconocimiento se asocian a niveles bajos.

La plantilla de Excel propuesta permite traducir cada respuesta a un valor numérico y calcular indicadores sintéticos.

### 4.3. Interpretación por categoría STRIDE

Para cada bloque STRIDE, la interpretación debe considerar:

- Cobertura (en qué proporción de sistemas/servicios se aplican las prácticas).
- Profundidad (si las prácticas son robustas o meramente formales).
- Sostenibilidad (si se basan en procesos repetibles y auditables).

Por ejemplo, en Spoofing, la pregunta sobre MFA se interpreta de forma diferente si la cobertura es alta pero sin gobierno ni métricas, que si la cobertura es moderada pero con plan de expansión y seguimiento estructurado.

## 5. Uso de resultados

### 5.1. Diagnóstico interno

Los resultados pueden emplearse para:

- Identificar brechas entre categorías STRIDE: por ejemplo, buena protección frente a DoS, pero debilidad en repudiación.
- Priorizar inversiones: qué controles ofrecen mayor reducción de riesgo en función de la situación de partida.
- Preparar auditorías NIS2, ENS u otras, alineando respuestas con evidencias.

### 5.2. Benchmarking externo

Si se recopilan respuestas de múltiples organizaciones, es posible:

- Calcular percentiles por sector, tamaño y tipología (esencial/important).
- Establecer referencias para iniciativas sectoriales (por ejemplo, en sanidad, energía o finanzas).
- Alimentar informes anuales de ciberseguridad a nivel país, con lectura STRIDE.

### 5.3. Actualización periódica

Se recomienda aplicar la encuesta:

- Al menos una vez al año, en paralelo con revisiones de riesgos y planes de seguridad.
- Tras cambios normativos relevantes (por ejemplo, entrada en vigor de NIS2 a nivel nacional).
- Tras incidentes significativos, para medir la respuesta y ajustes realizados.

## 6. Consideraciones sobre calidad de datos

### 6.1. Riesgo de sesgo optimista

Es natural que las organizaciones se autopuntúen con cierta benevolencia. Para mitigar:

- Acompañe las respuestas de evidencias (políticas, informes, métricas reales).
- Contraste la percepción de distintas áreas (técnicas y de negocio).
- Mantenga registro de discrepancias internas como indicador de alineamiento.

### 6.2. Granularidad y “no sabe/no contesta”

Es preferible contestar “No se ha analizado” o “No se mide” antes que forzar una respuesta optimista. Esa honestidad es valiosa para:

- Planificar ejercicios de medición y gobierno de métricas.
- Identificar áreas donde la prioridad es, precisamente, empezar a medir.

## 7. Mapeo normativo (resumen)

Cada pregunta se ha diseñado pensando en su posible alineamiento con:

- NIS2: en particular, artículos sobre gestión de riesgos, medidas técnicas y organizativas, y reporting de incidentes. [web:31][web:37][web:40]
- ENS: principios básicos y requisitos de organización, protección y operación.
- Otros marcos sectoriales (DORA, requisitos de supervisores financieros, AI Act, etc.).

El documento “Mapeo de preguntas a requisitos normativos” detalla estas correspondencias.

## **8. Uso responsable: ironía sí, cinismo no**

La encuesta adopta un tono deliberadamente humano, con guiños irónicos. La intención es bajar las defensas culturales sin bajar las defensas técnicas.

Se invita a las organizaciones a usar los resultados como oportunidad de mejora y de diálogo con la dirección, no como inventario de culpas. STRIDE, al fin y al cabo, solo describe las formas en que algo puede fallar; lo interesante es lo que ustedes decidan hacer para que no falle donde más importa.